

PMG Cyber Threat Intelligence

Threat Actor Report

UNC5221 is a China-nexus espionage threat actor that the PMG CTI team has been actively tracking since October 2023. This group has increasingly focused its operations on the healthcare sector, targeting critical infrastructure and sensitive patient data within hospitals, clinics, and healthcare service providers.

Their primary initial access vector remains the exploitation of vulnerabilities in widely deployed enterprise-grade Virtual Private Network (VPN) appliances, such as Ivanti Connect Secure. After gaining a foothold, UNC5221 leverages a custom malware toolset designed for stealth and persistent presence within healthcare IT systems.

Targeting Scope

UNC5221 targeted nearly a dozen public and private industries over a wide geographic area covering North America, Europe, Africa, and East Asia.



Industried Targetted

UNC5221 targeted a wide range of industries, with a specific focus on healthcare and Government.. The following is a list of UNC5221-targeted industries:

- Aerospace & defense
- Automotive
- Government
- Healthcare
- Manufacturing
- Technology
- Telecommunications
- Transportation

UNC5221 Significant Campaigns

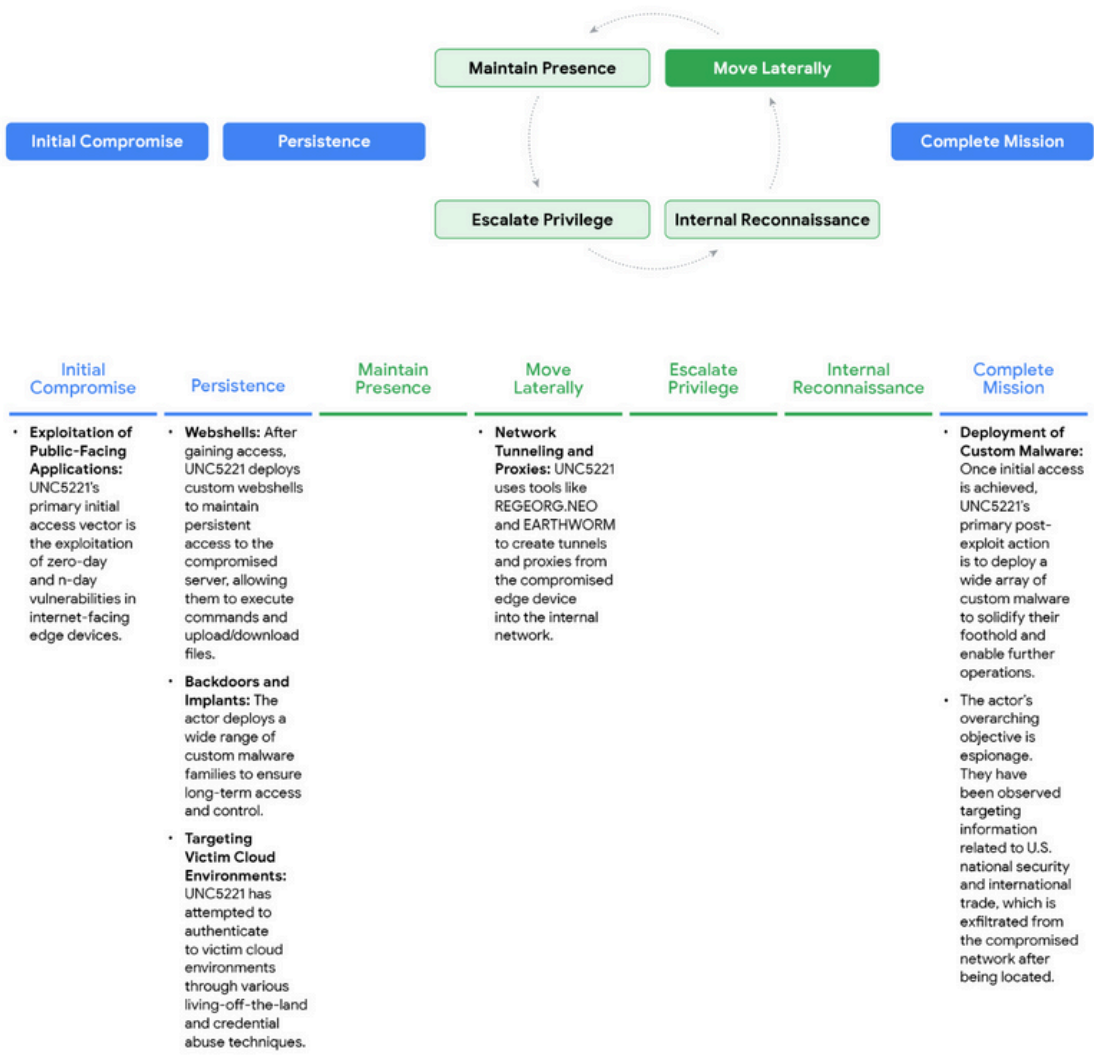
The following list provides an overview of significant UNC5221 activity, including information from a US indictment that associates UNC5221 activity with [APT27](#). While public reporting has conflated UNC5221 operations with APT27, GTIG is still in the process of establishing connections between the groups.

- On March 5, 2025, the US Department of Justice (DOJ) unsealed an indictment against members of the Chinese espionage group APT27 (aka Threat Group 3390, Bronze Union, Emissary Panda, Lucky Mouse, and Iron Tiger, which more recently is referred to as UTA0178 and Silk Typhoon/Hafnium). The DOJ highlighted a 2018 indictment against Yin Kecheng, providing additional details and insight into APT27 operations ([25-10015135](#)).
- In April 2025, UNC5221 exploited a critical buffer overflow vulnerability, [CVE-2025-22457](#), in Ivanti Connect Secure VPN appliances. Following exploitation, the actor deployed new malware families, including the [TRAILBLAZE](#) dropper and the [BRUSHFIRE](#) backdoor, as well as the [previously reported](#) SPAWN malware ecosystem. This highlights the actor's continued focus on exploiting both zero-day (0-day) and n-day vulnerabilities in edge devices ([25-10016692](#)).

- Since April 2024, UNC5221 has been observed exploiting vulnerabilities in edge devices, used compromised credentials, and deployed the BRICKSTORM backdoor in a campaign targeting the legal and software industries in the United States (CAMP.25.044).
 - As part of the ongoing campaign, in early 2025, UNC5221 compromised software-as-a-service (SaaS) providers likely to access downstream US legal and government targets as part of a campaign gathering information related to US national security and international trade. The actor deployed BRICKSTORM malware, uploaded custom web shells, and attempted SQL injection attacks (25-10035893).

Tactics, Techniques, and Procedures

UNC5221 employs the following methods for initial access, maintaining persistence, lateral movement, and post-exploitation behavior in compromised systems.



Initial Access

- Exploitation of public-facing applications: UNC5221's primary initial access vector is the exploitation of zero-day and n-day vulnerabilities in internet-facing edge devices. The group has demonstrated a rapid ability to operationalize exploits for newly disclosed flaws.
 - CVE-2023-46805 and CVE-2024-21887: Exploitation of authentication bypass and command injection vulnerabilities in Ivanti Connect Secure VPNs
 - CVE-2025-22457: Exploitation of a critical buffer overflow vulnerability in Ivanti Connect Secure VPNs
 - SQL Injection: Observed attempts of SQL injection attacks against target web applications to gain access to underlying databases and systems

Persistence

- Web shells: After gaining access, UNC5221 deploys custom web shells to maintain persistent access to the compromised server, allowing them to execute commands and upload/download files. The LIGHTWIRE web shell is one known example.
- Backdoors and implants: The actor deploys a wide range of custom malware families to ensure long-term access and control. These backdoors communicate with actor-controlled command-and-control (C2 or C&C) infrastructure. Known malware includes BRICKSTORM, BRUSHFIRE, ZIPLINE, and the extensive SPAWN malware ecosystem.
- Targeting victim cloud environments: UNC5221 has attempted to authenticate to victim cloud environments through various living-off-the-land (LotL) and credential abuse techniques.
 - Targeting Azure Active Directory Federation Services: UNC5221 has leveraged LotL techniques against victim Azure Active Directory Federation Services client applications to establish persistent access and traverse the victim environments. GTIG has observed UNC5221 make Graph API requests to extract user lists from the victim's Azure tenant and added new secrets to other Azure applications, indicating efforts to maintain access to the victim's Active Directory.

- Targeting Microsoft 365 Environments: UNC5221 has also attempted to access victim Microsoft 365 environments. In such cases, GTIG observed the actors conduct host-based data mining operations with PowerShell to collect data on system users and to gain access to /etc/passwd for credentials.

Lateral Movement

- Network tunneling and proxies: UNC5221 uses tools like REGEORG.NEO and EARTHWORM to create tunnels and proxies from the compromised edge device into the internal network. This allows them to pivot to other systems that are not directly accessible from the internet.

Complete Mission

- Deployment of custom malware: Once initial access is achieved, UNC5221's primary post-exploit action is to deploy a wide array of custom malware to solidify their foothold and enable further operations. Observed malware includes multiple backdoors (BRICKSTORM, BRUSHFIRE, ZIPLINE), web shells (LIGHTWIRE), droppers (TRAILBLAZE), and the comprehensive SPAWN malware ecosystem.
- Espionage and data exfiltration: The actor's overarching objective is espionage. They have been observed targeting information related to US national security and international trade, which is exfiltrated from the compromised network after being located. UNC5221 has been observed targeting this information by directly accessing victim mailboxes and conducting selective searches for sensitive information. The actors have also targeted data stored in SharePoint Online environments, through which they downloaded and exfiltrated the files of interest.